

The report is saved to `docs/discovery/06-security.md` in the target repo (branch `discovery/security-report-20260710` , PR [#2](#)) via the cloud-only GitHub REST workflow. Below are the required chat sections, copied verbatim from the saved report.

OVERALL CODEBASE RATING — SECURITY

High Risk

Driven by an unauthenticated API surface (A01/A07 Critical), a ~4/KLOC vulnerability density, and OWASP Top-10 compliance below 80%.

EXECUTIVE SUMMARY

This is a static, read-only review of the Klearcom platform covering all three layers: a Laravel 12 (PHP 8.3) REST API, a React 19 + TypeScript (Vite) single-page frontend, and a Node/Express dev-api mock. The dominant, systemic weakness is a total absence of authentication and authorization — every `/api/*` route (KPIs, discovery jobs, connect monitors, MongoDB transcripts/diagnostics) is publicly reachable with no session, token, or ownership check, which is both Broken Access Control (A01) and Identification & Authentication Failure (A07). This is compounded by a fully permissive CORS policy (`allowed_origins: ['*']`), an `extract($request->all())` variable-injection sink in the legacy report controller, and a NoSQL operator-injection vector in the dev-api transcripts endpoint. Configuration hygiene is weak — `APP_DEBUG=true` is baked into committed config and Compose, and plaintext DB credentials (`root` / `secret`) are committed in `docker-compose.yml`, `.env.example`, and CI. The frontend is comparatively clean: React's auto-escaping means no XSS sinks were found, no secrets are bundled, and no auth tokens are stored in browser storage — but there is no Content-Security-Policy anywhere and the API base defaults to plaintext `http://`. Dependencies are current (Laravel 12, React 19, Vite 6, mongodb 6/2) with no flagged CVEs, but CI runs no SAST or dependency scan. Overall rating is **High Risk**, driven by the missing-auth Critical plus a vulnerability density of ~4/KLOC and sub-80% OWASP compliance.

6.1 Security Benchmark Ratings

#	Security KPI	Target	GOOD	MODERATE	HIGH RISK	Measured	Rating
H1	Critical Vulnerabilities	0	0	1	>1	1 (missing auth)	MODERATE
H2	High Vulnerabilities	0	<5	5–10	>10	3	GOOD
H3	Medium Vulnerabilities	low	<20	20–50	>50	6	GOOD
H4	Vulnerability Density	<0.5/KLOC	<0.5	0.5–1.0	>1.0	~4.1/KLOC	HIGH RISK
H5	OWASP Top 10 Compliance	>95%	>95%	80–95%	<80%	~30% (3/10 clean)	HIGH RISK

H6	Critical/High Vulnerable Deps	0	0	1	>1	0	GOOD
H7	Outdated Dependencies	<10%	<10%	10–25%	>25%	~0%	GOOD
H8	End-of-Life Dependencies	0	0	1–5	>5	0	GOOD

6.3 OWASP Top 10 (2021) Coverage

#	Category	Verdict	Evidence / Note
A01	Broken Access Control	CRITICAL	No auth/authorization on any <code>/api/*</code> route; IDOR by design via <code>findOrFail(\$id)</code> — see §6.2 Missing Auth
A02	Cryptographic Failures	MEDIUM	Plaintext DB credentials committed in Compose/env/CI; no TLS enforcement on API base
A03	Injection	HIGH	<code>extract(\$request->all())</code> variable injection (PHP) + NoSQL operator injection in dev-api transcripts. SQLi itself not observed (Eloquent ORM, no raw SQL)
A04	Insecure Design	MEDIUM	No rate limiting/throttle on any route; unvalidated <code>bulk-import</code> ; unbounded dispatched jobs
A05	Security Misconfiguration	HIGH	Wildcard CORS, <code>APP_DEBUG=true</code> in committed config, no CSP/security headers
A06	Vulnerable & Outdated Components	CLEAN	Dependencies current (Laravel 12, React 19, Vite 6, mongodb 6/2); no CVE-flagged packages — but no CI scan exists (tracked under DevSecOps)
A07	Identification & Authentication Failures	CRITICAL	No authentication mechanism whatsoever — no login, tokens, MFA, or session management
A08	Software & Data Integrity Failures	CLEAN	No insecure deserialization or unsigned-update paths; deps installed from official registries
A09	Security Logging & Monitoring Failures	MEDIUM	No audit logging of access/auth/state-change events; only <code>console.error</code> on task failure
A10	Server-Side Request Forgery (SSRF)	CLEAN	No server-side HTTP calls built from user-supplied URLs/hosts observed
A11	Other (file upload / mass assignment / path traversal)	MEDIUM	Mass-assignment via <code>bulk-import</code> spread of arbitrary <code>item</code> fields (dev-api); no file-upload or path-traversal sinks observed
A12	DevSecOps	MEDIUM	CI runs no dependency-audit, SAST, or secret-scan; committed secrets would go undetected

6.5 Actions Required

Finding	Action	Rating	Priority
---------	--------	--------	----------

Missing Authentication & Authorization (A01/A07)	Add Sanctum/JWT guard on the API group; enforce ownership Policies; mirror in dev-api	HIGH RISK	CRITICAL
Fully permissive CORS (A05)	Replace <code>['*']</code> with an env-driven origin allow-list; restrict methods/headers	HIGH RISK	HIGH
<code>extract()</code> variable injection (A03)	Remove <code>extract()</code> ; use validated named inputs and array-key access	MODERATE	HIGH
NoSQL operator injection — dev-api (A03)	Coerce <code>module</code> to string and whitelist before Mongo <code>find</code>	MODERATE	HIGH
Debug mode in committed config (A05)	Force <code>APP_DEBUG=false</code> / <code>APP_ENV=production</code> outside local; add prod guard	MODERATE	MEDIUM
Committed plaintext credentials (A02)	Move secrets to a manager; replace committed values with placeholders	MODERATE	MEDIUM
Missing CSP / security headers + http default (A05)	Add CSP + security headers at nginx; enforce https API base	MODERATE	MEDIUM
No rate limiting / mass-assignment bulk-import (A04)	Add throttling; validate payload size/shape; cap concurrent jobs	MODERATE	MEDIUM
No security logging & monitoring (A09)	Emit structured audit events; ship to SIEM; alert on failures	MODERATE	MEDIUM
No SAST / dependency scanning in CI (A06/DevSecOps)	Add composer/npm audit + CodeQL/gitleaks + dependency-review gate	MODERATE	MEDIUM

Detected stack: Laravel 12 / PHP 8.3 (Eloquent ORM, MariaDB + MongoDB) backend · React 19 + TypeScript / Vite 6 SPA · Node/Express dev-api. **Layers covered:** backend, frontend, and the Node dev-api. The `06-security.md` deliverable is committed to the target repo and ready for the orchestration UI to convert to `06-security.pdf`.